

Fraud Readiness Advisory Report

An evidence-linked view of reported readiness, material risk, control priorities and leadership decisions.

PREPARED EXCLUSIVELY FOR

Journey 6 Organisation

Report reference RPT-MKFRS-2026-1FB942BC02-V1

Generated 7 August 2026

Essential Self-Assessment Report package

CONFIDENTIAL · INTERNAL LEADERSHIP USE

Contents

Executive summary	—
What the result means	—
Domain overview	—
Priority findings, contradictions and scenarios	—
Priority risks	—
Leadership decisions and roadmap	—
Evidence validation priorities	—
Methodology, limitations and next steps	—
Complete supporting detail	—
Appendix: supporting material	—
E1. Supporting control actions	—
E2. Definitions and score basis	—

Executive summary

Systemic foundational control gap

0

out of 100

Reactive

The assessment was answered with complete visibility, and it reports that the foundational fraud-control baseline is not yet in place. This is a systemic condition rather than an uncertainty: the control position is known, and it is that the baseline controls this report sets out have not been established.

SYSTEMIC CONDITION

This assessment records an absence of foundational fraud controls across 10 of 10 assessed domains, covering 100% of the applicable controls. Individual control findings are therefore of limited value on their own: the organisation does not yet have a fraud control baseline to improve. This report prioritises establishing that baseline.

LEADERSHIP ATTENTION

The immediate priority is visibility: knowing what is happening before a loss reveals it.

COVERAGE

100%

CRITICAL GAPS

19

MAJOR GAPS

17

Assessment scope and limitations

APPLICABLE CONTROLS

60

CONTROL VISIBILITY

100%

EXCLUDED AREAS

8

UNCERTAINTY RESPONSES

0

This is a provisional result. Differences in assessed scope or uncertainty may limit comparison with other assessments.

Use as a directional result only; differences in scope or uncertainty may limit comparison with other assessments.

The aggregate result and its ten underlying domains

The Reactive result describes the reported self-assessment position. It does not, by itself, establish operating effectiveness.

Fraud Leadership and Governance

0

Reactive

Fraud Risk Identification

0

Reactive

Operational Fraud Controls

0

Reactive

Fraud Detection Capability

0

Reactive

Fraud Incident Response

0

Reactive

Whistleblowing and Reporting Culture

0

Reactive

Third-Party and Supply Chain Fraud Risk

0

Reactive

Digital and Identity Fraud Risk

0

Reactive

Fraud Culture and Awareness

0

Reactive

Continuous Improvement and Fraud Risk Monitoring

0

Reactive

The recorded conditions requiring first attention

CRITICAL CONTROL CONDITION · FRAUD LEADERSHIP AND GOVERNANCE

Persisted control statement for D1-Q01.

Within Fraud Leadership and Governance, the specific control on whether persisted control statement for D1-Q01 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

CRITICAL CONTROL CONDITION · FRAUD LEADERSHIP AND GOVERNANCE

Persisted control statement for D1-Q04.

Within Fraud Leadership and Governance, the specific control on whether persisted control statement for D1-Q04 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

CRITICAL CONTROL CONDITION · FRAUD RISK IDENTIFICATION

Persisted control statement for D2-Q01.

Within Fraud Risk Identification, the specific control on whether persisted control statement for D2-Q01 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

CRITICAL CONTROL CONDITION · FRAUD RISK IDENTIFICATION

Persisted control statement for D2-Q02.

Within Fraud Risk Identification, the specific control on whether persisted control statement for D2-Q02 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

CRITICAL CONTROL CONDITION · OPERATIONAL FRAUD CONTROLS

Persisted control statement for D3-Q01.

Within Operational Fraud Controls, the specific control on whether persisted control statement for D3-Q01 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

CRITICAL CONTROL CONDITION · OPERATIONAL FRAUD CONTROLS

Persisted control statement for D3-Q03.

Within Operational Fraud Controls, the specific control on whether persisted control statement for D3-Q03 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

Persisted control statement for D3-Q04.

Within Operational Fraud Controls, the specific control on whether persisted control statement for D3-Q04 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

Persisted control statement for D4-Q01.

Within Fraud Detection Capability, the specific control on whether persisted control statement for D4-Q01 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

Persisted control statement for D4-Q03.

Within Fraud Detection Capability, the specific control on whether persisted control statement for D4-Q03 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

Persisted control statement for D5-Q01.

Within Fraud Incident Response, the specific control on whether persisted control statement for D5-Q01 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

Persisted control statement for D5-Q05.

Within Fraud Incident Response, the specific control on whether persisted control statement for D5-Q05 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

Persisted control statement for D6-Q01.

Within Whistleblowing and Reporting Culture, the specific control on whether persisted control statement for D6-Q01 scored low enough to be flagged as a critical gap. This is a specific, addressable control weakness rather than a general judgement on the whole domain.

Persisted control statement for D7-Q01.

Within Third-Party and Supply Chain Fraud Risk, the specific control on whether persisted control statement for D7-Q01 scored low enough to be flagged as a critical gap. This is a specific, addressable control weakness rather than a general judgement on the whole domain.

Persisted control statement for D7-Q04.

Within Third-Party and Supply Chain Fraud Risk, the specific control on whether persisted control statement for D7-Q04 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

Persisted control statement for D8-Q01.

Within Digital and Identity Fraud Risk, the specific control on whether persisted control statement for D8-Q01 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

Persisted control statement for D8-Q02.

Within Digital and Identity Fraud Risk, the specific control on whether persisted control statement for D8-Q02 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

Persisted control statement for D8-Q04.

Within Digital and Identity Fraud Risk, the specific control on whether persisted control statement for D8-Q04 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

Persisted control statement for D8-Q08.

Within Digital and Identity Fraud Risk, the specific control on whether persisted control statement for D8-Q08 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

Persisted control statement for D10-Q01.

Within Continuous Improvement and Fraud Risk Monitoring, the specific control on whether persisted control statement for D10-Q01 scored low enough to be flagged as a critical gap. This is one of the controls that can limit the overall maturity interpretation because strength elsewhere cannot fully compensate for it.

Where this organisation may look stronger than it really is

MATURITY CONSTRAINT · FRAUD LEADERSHIP AND GOVERNANCE

Persisted control statement for D1-Q01.

This recorded condition limits the final maturity reading to **Developing**. The constraint remains a self-assessment result until operating evidence is independently examined.

MATURITY CONSTRAINT · CROSS-DOMAIN

Three or more critical controls scored 0, 1 or 2.

This recorded condition limits the final maturity reading to **Developing**. The constraint remains a self-assessment result until operating evidence is independently examined.

MATURITY CONSTRAINT · FRAUD LEADERSHIP AND GOVERNANCE

Core domain D1 scored below 40.

This recorded condition limits the final maturity reading to **Developing**. The constraint remains a self-assessment result until operating evidence is independently examined.

MATURITY CONSTRAINT · FRAUD LEADERSHIP AND GOVERNANCE

Core domain D1 scored below 60.

This recorded condition limits the final maturity reading to **Structured**. The constraint remains a self-assessment result until operating evidence is independently examined.

An average can hide two very different situations behind the same number: consistent, moderate performance everywhere, or strong performance in many places sitting beside one seriously weak control. This result needs the second possibility to be taken seriously. Strength elsewhere cannot fully compensate for a control weakness that changes the overall readiness conclusion.

Domain overview

Every assessed domain is summarised below. Individual domain narratives are omitted because the recorded condition is systemic rather than domain-specific.

DOMAIN	WEIGHT	SCORE	CONTROLS IN SCOPE	RECORDED ABSENT
Fraud Leadership and Governance	12%	0/100	6	6
Fraud Risk Identification	12%	0/100	8	8
Operational Fraud Controls	14%	0/100	7	7
Fraud Detection Capability	14%	0/100	7	7
Fraud Incident Response	10%	0/100	7	7
Whistleblowing and Reporting Culture	6%	0/100	4	4
Third-Party and Supply Chain Fraud Risk	10%	0/100	7	7
Digital and Identity Fraud Risk	12%	0/100	7	7
Fraud Culture and Awareness	5%	0/100	1	1
Continuous Improvement and Fraud Risk Monitoring	5%	0/100	6	6

Priority findings, contradictions and scenarios

The 6 conditions selected for executive attention from 60 recorded findings. The complete register of all 60 findings is provided in the supporting register issued with this report.

MATERIAL FINDING 1

MATURITY CONSTRAINT

Fraud Leadership and Governance: Persisted control statement for D1-Q01.

DOMAIN
Fraud Leadership and Governance
DIAGNOSIS
Senior fraud-risk ownership was self-assessed as "Not in place" (Official operational meaning for response 0; normalised score 0/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.
RECOMMENDED CONTROL
The CEO must issue a dated fraud-risk accountability mandate naming one executive, delegated decision rights, budget authority, quarterly reporting obligations and a 30-day escalation route for overdue control actions; the company secretary retains approvals and quarterly packs.

RECORDED CONTROL CONDITION
Persisted control statement for D1-Q01. — Not in place
WHY IT MATTERS
This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.
ACCOUNTABLE EXECUTIVE
CEO / Managing Director

IMPLEMENTATION
Low difficulty · 30 days

REMAINING LIMITATION
Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

MATERIAL FINDING 2

CONTROL FAILURE

Operational Fraud Controls: Persisted control statement for D3-Q03.

DOMAIN
Operational Fraud Controls
DIAGNOSIS
Supplier-onboarding verification was self-assessed as "Not in place" (Official operational meaning for response 0; normalised score 0/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.
RECOMMENDED CONTROL
Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.

RECORDED CONTROL CONDITION
Persisted control statement for D3-Q03. — Not in place
WHY IT MATTERS
This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.
ACCOUNTABLE EXECUTIVE
CFO / COO

IMPLEMENTATION
Moderate difficulty · 60 days

REMAINING LIMITATION
Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

MATERIAL FINDING 3

CONTROL FAILURE

Digital and Identity Fraud Risk: Persisted control statement for D8-Q02.

DOMAIN
Digital and Identity Fraud Risk

RECORDED CONTROL CONDITION
Persisted control statement for D8-Q02. — Not in place

DIAGNOSIS
Suspicious digital-activity monitoring was self-assessed as "Not in place" (Official operational meaning for response 0; normalised score 0/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.
RECOMMENDED CONTROL
The security monitoring owner inventories material login, privilege, profile and transaction events, implements risk rules across the full in-scope event feed, assigns alerts to trained analysts, preserves dispositions and escalates high-risk account compromise immediately; monthly tuning uses confirmed true/false positives.
IMPLEMENTATION
High difficulty · 90 days

WHY IT MATTERS
This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.
ACCOUNTABLE EXECUTIVE
Chief Technology Officer
REMAINING LIMITATION
Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

MATERIAL FINDING 4

CONTROL FAILURE

Fraud Incident Response: Persisted control statement for D5-Q01.

DOMAIN
Fraud Incident Response
DIAGNOSIS
Fraud incident-response governance was self-assessed as "Not in place" (Official operational meaning for response 0; normalised score 0/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.
RECOMMENDED CONTROL
The incident-response lead maintains a version-controlled plan covering every reported fraud incident, names an incident commander and deputies, classifies severity at intake, convenes Legal/HR/IT/Finance roles, records decisions and containment actions, and runs an annual tabletop with tracked remediation.
IMPLEMENTATION
Moderate difficulty · 30 days

RECORDED CONTROL CONDITION
Persisted control statement for D5-Q01. — Not in place
WHY IT MATTERS
This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.
ACCOUNTABLE EXECUTIVE
COO / General Counsel
REMAINING LIMITATION
Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

MATERIAL FINDING 5

CONTROL FAILURE

Third-Party and Supply Chain Fraud Risk: Persisted control statement for D7-Q04.

DOMAIN
Third-Party and Supply Chain Fraud Risk
DIAGNOSIS
Supplier payment and bank-detail-change verification was self-assessed as "Not in place" (Official operational meaning for response 0; normalised score 0/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.
RECOMMENDED CONTROL
Accounts Payable quarantines every bank-detail change, retrieves a contact from the pre-change vendor master, completes and records an outbound callback, obtains second-person approval from someone outside vendor-master maintenance, blocks payment until verification, and gives the CFO a monthly report of all changes, failures and bypass attempts.
IMPLEMENTATION
Moderate difficulty · 30 days

RECORDED CONTROL CONDITION
Persisted control statement for D7-Q04. — Not in place
WHY IT MATTERS
This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.
ACCOUNTABLE EXECUTIVE
CFO
REMAINING LIMITATION
Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

Fraud Detection Capability: Persisted control statement for D4-Q01.

DOMAIN Fraud Detection Capability	RECORDED CONTROL CONDITION Persisted control statement for D4-Q01. — Not in place
DIAGNOSIS Transaction and activity monitoring was self-assessed as "Not in place" (Official operational meaning for response o; normalised score 0/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.	WHY IT MATTERS This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.
RECOMMENDED CONTROL The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with named reviewers and SLAs; coverage against the process fraud maps is reported to the fraud forum.	ACCOUNTABLE EXECUTIVE CFO / COO
IMPLEMENTATION Moderate difficulty · 90 days	REMAINING LIMITATION Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

Contradictions

CONTRADICTION 1 Operational and privileged-access weaknesses indicate one systemic access-governance issue	
WHAT THE ASSESSMENT SHOWS	Digital and Identity Fraud Risk — Not in place — Official operational meaning for response o; Operational Fraud Controls — Not in place — Official operational meaning for response o
WHY IT MATTERS	Excess access across ordinary and privileged environments can create an end-to-end manipulation and concealment route.
LEADERSHIP VERIFICATION	Is one complete identity, role and recertification population used across ordinary and privileged access reviews?

Scenarios and assurance tests

SCENARIO 1 · CONTROL GAP

Controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier
This is a plausible scenario derived from the organisation's self-assessment evidence. It is not an allegation that the event has occurred.

ENTRY POINT
An interaction covered by the recorded control condition: Continuous Improvement and Fraud Risk Monitoring: Persisted control statement for D10-Q01.
EARLY WARNING INDICATORS
- An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population. - Review overdue, or a key control found lapsed with no remediation owner.

LONGER-TERM RESPONSE
The Head of Risk must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.

SCENARIO 2 · CONTROL GAP

Without a current structured assessment, control investment follows intuition and recent events, leaving whole exposure areas unexamined and unfunded

This is a plausible scenario derived from the organisation's self-assessment evidence. It is not an allegation that the event has occurred.

ENTRY POINT
An interaction covered by the recorded control condition: Fraud Risk Identification: Persisted control statement for D2-Q01.
EARLY WARNING INDICATORS
- An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population. - Assessment older than 24 months, or any unacceptable residual risk without a funded owner and due date.

LONGER-TERM RESPONSE
The Head of Risk must run a documented fraud risk assessment at least every two years using a repeatable method: scope the material processes and channels, identify fraud scenarios per process with the roles able to execute them, rate likelihood and impact before and after existing controls, name a treatment owner and due date for every unacceptable residual risk, and obtain governing-body approval of the plan; assessment date, participants and method are retained.

SCENARIO 3 · CONTROL GAP

Organisation-level risk statements hide process-level opportunity, so a specific diversion route such as refund abuse or stock write-off manipulation is never mapped to a control owner

This is a plausible scenario derived from the organisation's self-assessment evidence. It is not an allegation that the event has occurred.

SEQUENCE
An actor exploits the recorded control condition so that controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier.
IMMEDIATE CONTAINMENT
Escalate to CEO / Managing Director, preserve relevant records and apply the control's escalation threshold: Review overdue, or a key control found lapsed with no remediation owner.

SEQUENCE
An actor exploits the recorded control condition so that without a current structured assessment, control investment follows intuition and recent events, leaving whole exposure areas unexamined and unfunded.
IMMEDIATE CONTAINMENT
Escalate to CEO / Managing Director, preserve relevant records and apply the control's escalation threshold: Assessment older than 24 months, or any unacceptable residual risk without a funded owner and due date.

ENTRY POINT An interaction covered by the recorded control condition: Fraud Risk Identification: Persisted control statement for D2-Qo2.
EARLY WARNING INDICATORS • An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population. • Any material process unmapped, or a mapped residual gap with no owner.

LONGER-TERM RESPONSE
The Head of Risk must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.

SCENARIO 4 · CONTROL GAP

Segregation-of-duties weakness enables end-to-end transaction control

This is a plausible scenario derived from the organisation's self-assessment evidence. It is not an allegation that the event has occurred.

ENTRY POINT A user or role able to initiate and approve the same transaction without independent maker-checker evidence.
EARLY WARNING INDICATORS • An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population. • Any user holding initiation and approval rights over the same transaction type without an approved compensating control.
LONGER-TERM RESPONSE Process owners must document the four duties for each high-risk process, map them to distinct named roles, configure system permissions so incompatible duties cannot be held together, and run a periodic conflict report against actual user entitlements; where team size prevents separation, the CFO approves a written compensating control such as independent after-the-fact review of the complete transaction population by someone outside the process.

SCENARIO 5 · CONTROL GAP

Without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded

This is a plausible scenario derived from the organisation's self-assessment evidence. It is not an allegation that the event has occurred.

SEQUENCE An actor exploits the recorded control condition so that organisation-level risk statements hide process-level opportunity, so a specific diversion route such as refund abuse or stock write-off manipulation is never mapped to a control owner.
IMMEDIATE CONTAINMENT Escalate to CFO / COO, preserve relevant records and apply the control's escalation threshold: Any material process unmapped, or a mapped residual gap with no owner.

SEQUENCE An actor exploits the recorded control condition so that where one person controls a transaction end to end they can create, authorise and conceal a fictitious payment, credit or stock movement without any second party noticing.
IMMEDIATE CONTAINMENT Escalate to CFO / COO, preserve relevant records and apply the control's escalation threshold: Any user holding initiation and approval rights over the same transaction type without an approved compensating control.

ENTRY POINT

An interaction covered by the recorded control condition: Fraud Detection Capability: Persisted control statement for D4-Q01.

EARLY WARNING INDICATORS

- A material process unmonitored, or a monitoring cycle missed without escalation.
- An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population.

LONGER-TERM RESPONSE

The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with named reviewers and SLAs; coverage against the process fraud maps is reported to the fraud forum.

SEQUENCE

An actor exploits the recorded control condition so that without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded.

IMMEDIATE CONTAINMENT

Escalate to CFO / COO, preserve relevant records and apply the control's escalation threshold: A material process unmonitored, or a monitoring cycle missed without escalation.

Priority risks

Priority is derived from the assessment evidence and is not an independent risk assessment. The complete risk register (56 risks) is provided in the supporting register issued with this report.

RISK 1 · D4

CRITICAL

Fraud Detection Capability control effectiveness risk

Because the assessed control design or operation does not meet the exact expected standard, there is a risk that without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded. Consequence pathway: Alert backlogs can conceal important anomalies; unreviewed exceptions can allow losses to compound.

CAUSE
the assessed control design or operation does not meet the exact expected standard

LIKELIHOOD
High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

CURRENT CONTROL POSITION
Fraud Detection Capability: Not in place — Official operational meaning for response 0

ACCOUNTABLE EXECUTIVE
CFO / COO

RISK EVENT
without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded

IMPACT
Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

REQUIRED TREATMENT
The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with named reviewers and SLAs; coverage against the process fraud maps is reported to the fraud forum.

TARGET PERIOD
90 days

RISK 2 · D8

CRITICAL

Digital account compromise or misuse is not detected promptly

Because material login, access, profile and transaction events are not completely monitored and triaged, there is a risk that a compromised or malicious identity uses digital channels without timely detection and response. Consequence pathway: customers and partners lose trust in digital channels; digital operations must contain and investigate a wider incident; security or personal-data notification duties may arise; unauthorised transactions or account changes cause direct loss.

CAUSE
material login, access, profile and transaction events are not completely monitored and triaged

LIKELIHOOD
High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

RISK EVENT
a compromised or malicious identity uses digital channels without timely detection and response

IMPACT
Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION
Digital and Identity Fraud Risk: Not in place — Official operational meaning for response o
ACCOUNTABLE EXECUTIVE
Chief Technology Officer

REQUIRED TREATMENT
Digital Operations and Security define misuse cases for unauthorised transactions, sensitive-data changes and channel abuse, monitor the complete in-scope event population, link events by user/device/account, triage alerts to SLA and review monthly control totals and missed-case feedback. The security monitoring owner inventories material login, privilege, profile and transaction events, implements risk rules across the full in-scope event feed, assigns alerts to trained analysts, preserves dispositions and escalates high-risk account compromise immediately; monthly tuning uses confirmed true/false positives.
TARGET PERIOD
90 days

RISK 3 · D1

CRITICAL

Fraud-risk accountability and escalation failure

Because executive fraud-risk accountability, authority and escalation are not supported by the required operating evidence, there is a risk that material fraud-control gaps remain unresolved or accepted without an authorised decision. Consequence pathway: cross-functional actions remain ownerless or overdue; leadership may be unable to demonstrate active stewardship of known fraud risks; losses continue because required resources or corrective action are delayed.

CAUSE
executive fraud-risk accountability, authority and escalation are not supported by the required operating evidence
LIKELIHOOD
High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.
CURRENT CONTROL POSITION
Fraud Leadership and Governance: Not in place — Official operational meaning for response o
ACCOUNTABLE EXECUTIVE
CEO / Managing Director

RISK EVENT
material fraud-control gaps remain unresolved or accepted without an authorised decision
IMPACT
High — High impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.
REQUIRED TREATMENT
The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes. The CEO must issue a dated fraud-risk accountability mandate naming one executive, delegated decision rights, budget authority, quarterly reporting obligations and a 30-day escalation route for overdue control actions; the company secretary retains approvals and quarterly packs.
TARGET PERIOD
30 days

RISK 4 · D5

CRITICAL

Fraud incident response is delayed or uncoordinated

Because incident command, severity, containment and decision roles are not documented and rehearsed, there is a risk that a suspected fraud is handled inconsistently, delaying containment and escalation. Consequence pathway: containment, legal, HR, IT and communications decisions conflict or stall; losses and recovery costs increase while action is delayed; notification or investigation duties may be missed; poor crisis handling amplifies stakeholder harm.

CAUSE
incident command, severity, containment and decision roles are not documented and rehearsed
LIKELIHOOD
High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

RISK EVENT
a suspected fraud is handled inconsistently, delaying containment and escalation
IMPACT
Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION Fraud Incident Response: Not in place — Official operational meaning for response o	REQUIRED TREATMENT The incident-response lead maintains a version-controlled plan covering every reported fraud incident, names an incident commander and deputies, classifies severity at intake, convenes Legal/HR/IT/Finance roles, records decisions and containment actions, and runs an annual tabletop with tracked remediation.
ACCOUNTABLE EXECUTIVE COO / General Counsel	TARGET PERIOD 30 days

RISK 5 · D3, D7

CRITICAL

Fictitious or conflicted supplier enters the vendor population

Because supplier identity, ownership, banking and conflict checks are incomplete or not evidenced before activation, there is a risk that a fictitious, conflicted or misrepresented supplier is approved and used for purchasing or payment. Consequence pathway: funds are paid to an illegitimate or related party; procurement and vendor-master integrity are compromised; sanctions, conflict or procurement obligations may be breached; stakeholders lose confidence in supplier governance.

CAUSE supplier identity, ownership, banking and conflict checks are incomplete or not evidenced before activation	RISK EVENT a fictitious, conflicted or misrepresented supplier is approved and used for purchasing or payment
LIKELIHOOD High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.	IMPACT Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.
CURRENT CONTROL POSITION Operational Fraud Controls: Not in place — Official operational meaning for response o; Third-Party and Supply Chain Fraud Risk: Not in place — Official operational meaning for response o	REQUIRED TREATMENT Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package. The vendor-risk owner risk-rates every proposed third party, verifies legal identity and beneficial ownership from independent sources, screens sanctions/adverse and employee conflicts, documents capability and bank ownership, and requires Compliance approval for high-risk cases before contract signature or system activation.
ACCOUNTABLE EXECUTIVE CFO / COO	TARGET PERIOD 60 days

RISK 6 · D7

CRITICAL

Supplier payment is redirected through impersonation

Because invoice and bank-detail changes are not independently verified through a trusted pre-existing contact, there is a risk that an impersonator or insider redirects a legitimate supplier payment to an unauthorised account. Consequence pathway: a payment is irrecoverably transferred to a fraud-controlled account; recovery, disclosure or dispute obligations may arise; supplier settlement and service continuity are disrupted; suppliers lose confidence in payment controls.

CAUSE invoice and bank-detail changes are not independently verified through a trusted pre-existing contact	RISK EVENT an impersonator or insider redirects a legitimate supplier payment to an unauthorised account
LIKELIHOOD High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.	IMPACT Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION
Third-Party and Supply Chain Fraud Risk: Not in place — Official operational meaning for response o
ACCOUNTABLE EXECUTIVE
CFO

REQUIRED TREATMENT
Accounts Payable quarantines every bank-detail change, retrieves a contact from the pre-change vendor master, completes and records an outbound callback, obtains second-person approval from someone outside vendor-master maintenance, blocks payment until verification, and gives the CFO a monthly report of all changes, failures and bypass attempts.
TARGET PERIOD
30 days

Leadership decisions and roadmap

Leadership decisions required

Every decision below carries a named accountable executive and a fixed target period; each is grounded in the material findings, risks and controls set out in this report and in the complete registers in the appendix.

NO.	DECISION REQUIRED	RECOMMENDED DECISION	ACCOUNTABLE EXECUTIVE	TARGET PERIOD	CONSEQUENCE OF DELAY
1	Approve accountable executive mandates and escalation authority for priority remediation.	Name one accountable executive per linked control and approve a 30-day escalation route.	CEO / Managing Director	30 days	Priority controls remain ownerless or blocked and the maturity reading remains constrained.
2	Choose and record remediation rather than passive acceptance for Critical and High risks.	Approve linked treatments; any temporary acceptance must name an owner, expiry and compensating control.	CEO / Managing Director	30 days	Known risk pathways remain untreated without a documented acceptance basis.
3	Approve exact question-level control designs as the minimum implementation standard.	Adopt the control-improvement register; deviations require documented oversight approval.	CEO / Managing Director	30 days	Partial or inconsistent designs fail to address the causal pathway.
4	Approve specialist capacity and resources for high-difficulty controls.	Fund the named supporting functions and require a resource-confirmed delivery plan.	General Counsel / COO	60 days	The highest-complexity gaps remain open despite nominal approval.
5	Approve prerequisite-first sequencing for dependent improvements.	Use authoritative roadmap dependency IDs and escalate threatened prerequisites.	CEO / Managing Director	30 days	Downstream controls are implemented on incomplete foundations.
6	Approve a fixed governance cadence for evidence validation and overdue escalation.	Require monthly implementation reporting and quarterly independent evidence review.	CEO / Managing Director	30 days	Actions lose momentum and self-reported claims remain unverified.

Foundational control programme

Establishing a control baseline, in dependency order. Each step names the exact control recorded as absent.

STEP	DOMAIN	CONTROL TO ESTABLISH	ACCOUNTABLE OWNER	TARGET
1	Fraud Leadership and Governance	Persisted control statement for D1-Q01.	CEO / Managing Director	30 days
2	Operational Fraud Controls	Persisted control statement for D3-Q03.	CFO / COO	60 days
3	Digital and Identity Fraud Risk	Persisted control statement for D8-Q02.	Chief Technology Officer	90 days
4	Fraud Incident Response	Persisted control statement for D5-Q01.	COO / General Counsel	30 days
5	Third-Party and Supply Chain Fraud Risk	Persisted control statement for D7-Q04.	CFO	30 days
6	Fraud Detection Capability	Persisted control statement for D4-Q01.	CFO / COO	90 days

30/60/90-day roadmap

This is the report's only action roadmap. Dependencies and measures are carried directly from the material findings, risks and controls set out in this report.

Period	Domain	Deliverable	Accountable Executive	Success Measure
30 days	Fraud Leadership and Governance	Apply immediate escalation at "Any material control action without an owner or more than 30 days overdue." and deliver the exact control design: The CEO must issue a dated fraud-risk accountability mandate naming one executive, delegated decision rights, budget authority, quarterly reporting obligations and a 30-day escalation route for overdue control actions; the company secretary retains approvals and quarterly packs.	CEO / Managing Director	100% of material fraud actions have a funded owner and due date, with overdue items escalated within 30 days.
30 days	Fraud Incident Response	Apply immediate escalation at "Severe incident not escalated within four hours or annual tabletop overdue." and deliver the exact control design: The incident-response lead maintains a version-controlled plan covering every reported fraud incident, names an incident commander and deputies, classifies severity at intake, convenes Legal/HR/IT/Finance roles, records decisions and containment actions, and runs an annual tabletop with tracked remediation.	COO / General Counsel	All incidents receive a severity decision within four hours and annual tabletop actions close by due date.
60 days	Operational Fraud Controls	Apply immediate escalation at "Any supplier activated before verification or any ownership/conflict match unresolved." and deliver the exact control design: Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.	CFO / COO	100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval.
90 days	Digital and Identity Fraud Risk	Apply immediate escalation at "Priority feed outage, high-risk alert outside SLA or confirmed compromise not escalated." and deliver the exact control design: The security monitoring owner inventories material login, privilege, profile and transaction events, implements risk rules across the full in-scope event feed, assigns alerts to trained analysts, preserves dispositions and escalates high-risk account compromise immediately; monthly tuning uses confirmed true/false positives.	Chief Technology Officer	All priority event feeds monitored and 95% of high-risk alerts triaged within SLA.
90 days	Fraud Detection Capability	Apply immediate escalation at "A material process unmonitored, or a monitoring cycle missed without escalation." and deliver the exact control design: The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with named reviewers and SLAs; coverage against the process fraud maps is reported to the fraud forum.	CFO / COO	Monitoring covers all material processes on rhythm with reconciled population totals and routed output.
60 days	Third-Party and Supply Chain Fraud Risk	Apply immediate escalation at "Any engagement before due diligence or unresolved ownership, sanctions or conflict match." and deliver the exact control design: The vendor-risk owner risk-rates every proposed third party, verifies legal identity and beneficial ownership from independent sources, screens sanctions/adverse and employee conflicts, documents capability and bank ownership, and requires Compliance approval for high-risk cases before contract signature or system activation.	CFO / COO	100% of new third parties have completed risk-tiered due diligence before engagement.
30 days	Third-Party and Supply Chain Fraud Risk	Apply immediate escalation at "Any unverified change released, callback mismatch or attempt to bypass segregation." and deliver the exact control design: Accounts Payable quarantines every bank-detail change, retrieves a contact from the pre-change vendor master, completes and records an outbound callback, obtains second-person approval from someone outside vendor-master maintenance, blocks payment until verification, and gives the CFO a monthly report of all changes, failures and bypass attempts.	CFO	100% of bank-detail changes independently verified before the first payment; zero unapproved bypasses.

EVIDENCE VALIDATION PRIORITIES

Evidence validation priorities

closing section of this report).

NO.	EVIDENCE ARTEFACT	WHAT IT PROVES	LIKELY OWNER	STATUS
1	Last two fraud-risk governance packs	Whether Persisted control statement for D1-Q01 operates to the exact expected control standard across the complete in-scope population.	Named fraud-risk executive	Not yet requested
2	Overdue-action escalation log	Whether Persisted control statement for D1-Q01 operates to the exact expected control standard across the complete in-scope population.	Named fraud-risk executive	Not yet requested
3	Signed executive accountability mandate	Whether Persisted control statement for D1-Q01 operates to the exact expected control standard across the complete in-scope population.	Named fraud-risk executive	Not yet requested
4	Beneficial-ownership/conflict screening	Whether Persisted control statement for D3-Q03 operates to the exact expected control standard across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
5	Completed onboarding checklist	Whether Persisted control statement for D3-Q03 operates to the exact expected control standard across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
6	Independent registration and bank verification	Whether Persisted control statement for D3-Q03 operates to the exact expected control standard across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
7	Second-reviewer approval	Whether Persisted control statement for D3-Q03 operates to the exact expected control standard across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
8	Alert case records	Whether Persisted control statement for D8-Q02 operates to the exact expected control standard across the complete in-scope population.	Security monitoring / SOC	Not yet requested
9	In-scope event inventory	Whether Persisted control statement for D8-Q02 operates to the exact expected control standard across the complete in-scope population.	Security monitoring / SOC	Not yet requested
10	Monitoring-rule catalogue	Whether Persisted control statement for D8-Q02 operates to the exact expected control standard across the complete in-scope population.	Security monitoring / SOC	Not yet requested
11	Monthly tuning and coverage report	Whether Persisted control statement for D8-Q02 operates to the exact expected control standard across the complete in-scope population.	Security monitoring / SOC	Not yet requested
12	Annual tabletop record	Whether Persisted control statement for D5-Q01 operates to the exact expected control standard across the complete in-scope population.	Fraud incident-response lead	Not yet requested
13	Approved incident-response plan	Whether Persisted control statement for D5-Q01 operates to the exact expected control standard across the complete in-scope population.	Fraud incident-response lead	Not yet requested
14	Incident decision and action log	Whether Persisted control statement for D5-Q01 operates to the exact expected control standard across the complete in-scope population.	Fraud incident-response lead	Not yet requested
15	Lessons-learned tracker	Whether Persisted control statement for D5-Q01 operates to the exact expected control standard across the complete in-scope population.	Fraud incident-response lead	Not yet requested

Required population for every item: the complete in-scope population for the stated operating period, reconciled to the source system or register. Sampling expectation: review the complete population where feasible; otherwise use a documented risk-based sample including exceptions, changes and overdue items. Every item begins with the status "Not yet requested"; status changes require an evidence-review process outside this report. This remains a self-assessment: no document, interview, transaction sample or system evidence has been independently verified for any item.

METHODOLOGY, LIMITATIONS AND NEXT STEPS

Methodology, limitations and next steps

This report is generated from a structured self-assessment across ten fraud-risk-management domains. The score, maturity constraints and advisory model use only the recorded assessment inputs and the deterministic methodology.

Limitations. This is not a forensic investigation, external audit, compliance certification or guarantee. Responses were not independently verified. Findings, scenarios and recommendations are decision-support material; leadership should obtain and test the specified operating evidence before treating a control as effective or a finding as resolved.

Next step. Commission independent validation of the operating evidence listed in this report's evidence-validation section and appendix, in the sequence set by the leadership decisions above.

Recommended next step

Commission independent validation of the last two fraud-risk governance packs. Confirm across the complete in-scope population that persisted control statement for D1-Q01. This is the immediate validation priority; the complete sequence is set out in Evidence validation priorities above and the full checklist in the appendix.

Complete supporting detail

This report presents the highest-priority matters from a complete assessment of 68 controls. The full assessment identified 60 material findings, 56 risks, 60 control improvements, 243 evidence artefacts, 60 recommended actions and 130 functional-agenda items.

Every item not shown in this report is retained in full in the supporting register issued with it. No identified weakness has been discarded.

Appendix: supporting material

Bounded supporting material for the priority matters above. The complete authoritative registers are provided in the supporting register, not reproduced here.

E1. Supporting control actions

Further control actions beyond the priority set above, in materiality order.

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
1	Operational Fraud Controls	Close the material control weakness recorded for "Persisted control statement for D3-Q04".	System owners export the complete active-user population quarterly; line managers compare every entitlement to the approved role matrix, record keep/remove decisions, and route exceptions to IT for closure within 10 business days; Risk samples completed reviews and overdue removals are escalated to the COO.	COO / 60 days
2	Fraud Incident Response	Close the material control weakness recorded for "Persisted control statement for D5-Q05".	The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.	General Counsel / COO / 60 days
3	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Persisted control statement for D8-Q04".	IT Security maintains a complete privileged-account register, links each human and service account to an owner and approved justification, enforces separate named admin identities and MFA, records privileged sessions, and sends the full population quarterly to system owners and Risk for independent keep/remove certification; removals close within 24 hours for leavers and five business days otherwise.	Chief Technology Officer / 60 days
4	Continuous Improvement and Fraud Risk Monitoring	Close the material control weakness recorded for "Persisted control statement for D10-Q01".	The Head of Risk must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.	CEO / Managing Director / 90 days
5	Fraud Risk Identification	Close the material control weakness recorded for "Persisted control statement for D2-Q01".	The Head of Risk must run a documented fraud risk assessment at least every two years using a repeatable method: scope the material processes and channels, identify fraud scenarios per process with the roles able to execute them, rate likelihood and impact before and after existing controls, name a treatment owner and due date for every unacceptable residual risk, and obtain governing-body approval of the plan; assessment date, participants and method are retained.	CEO / Managing Director / 90 days
6	Operational Fraud Controls	Close the material control weakness recorded for "Persisted control statement for D3-Q01".	Process owners must document the four duties for each high-risk process, map them to distinct named roles, configure system permissions so incompatible duties cannot be held together, and run a periodic conflict report against actual user entitlements; where team size prevents separation, the CFO approves a written compensating control such as independent after-the-fact review of the complete transaction population by someone outside the process.	CFO / COO / 60 days
7	Fraud Detection Capability	Close the material control weakness recorded for "Persisted control statement for D4-Q03".	The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.	CFO / Chief Technology Officer / 90 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
8	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Persisted control statement for D8-Qo1".	The process owner must define the risk points requiring verification — customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting — and apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records, and confirmation of contact details through independently obtained channels; results and evidence are retained under applicable data-protection obligations, exceptions require documented approval, and sensitive profile or banking changes trigger re-verification.	COO / CFO / 60 days
9	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Persisted control statement for D8-Qo8".	The security operations owner must ensure authentication events, credential and multi-factor changes, profile and banking-detail changes, device and session identifiers and transaction history are logged for all material identity-bearing systems and retained for a defined period consistent with data-protection obligations; alerting covers impossible-travel and anomalous login, credential and contact-detail change followed by transaction, and dormant-account reactivation, with an investigation runbook defining containment such as session revocation and forced credential reset.	Chief Technology Officer / 90 days
10	Fraud Leadership and Governance	Close the material control weakness recorded for "Persisted control statement for D1-Qo4".	The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes.	CEO / Managing Director / 30 days
11	Fraud Risk Identification	Close the material control weakness recorded for "Persisted control statement for D2-Qo2".	The Head of Risk must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.	CFO / COO / 90 days
12	Whistleblowing and Reporting Culture	Close the material control weakness recorded for "Persisted control statement for D6-Qo1".	The ethics owner operates a web/telephone channel available to the full defined population, assigns case IDs without exposing reporter identity, limits case access by role, routes allegations away from implicated managers, acknowledges reports within two business days and reports retaliation concerns directly to the audit-committee chair.	Chair of Audit Committee / CEO / 60 days
13	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Persisted control statement for D8-Qo5".	Digital Operations and Security define misuse cases for unauthorised transactions, sensitive-data changes and channel abuse, monitor the complete in-scope event population, link events by user/device/account, triage alerts to SLA and review monthly control totals and missed-case feedback.	Chief Technology Officer / COO / 90 days
14	Operational Fraud Controls	Close the material control weakness recorded for "Persisted control statement for D3-Qo2".	The CFO must approve a delegation of authority matrix setting value and risk thresholds by transaction type, configure the finance and operational systems to block release above threshold without a second independent approver, prohibit self-approval and approval by direct reports of the initiator, and run a monthly report for split transactions falling just below thresholds and for any threshold override.	CFO / 60 days
15	Operational Fraud Controls	Close the material control weakness recorded for "Persisted control statement for D3-Qo5".	Finance and operations owners must extract the complete population of manual adjustments each period, require a mandatory reason code and supporting justification at capture, and have an independent reviewer outside the originating team examine all items above a risk threshold plus a random sample below it; repeat originators, round-value patterns and adjustments reversing prior-period entries are escalated to the CFO.	CFO / 60 days
16	Operational Fraud Controls	Close the material control weakness recorded for "Persisted control statement for D3-Qo6".	The Head of Risk must schedule reviews of material processes on a defined cycle, walk the process as actually performed including workarounds and manual steps, test a sample of transactions end to end, log identified weaknesses with an owner and due date, and report closure status to the fraud reporting forum; reviews prioritise processes with recent incidents, high manual intervention or recent change.	COO / 90 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
17	Operational Fraud Controls	Close the material control weakness recorded for "Persisted control statement for D3-Qo7".	Human Resources and the Head of Risk must jointly define high-risk roles by authority, system access and asset custody, and apply documented measures to each: secondary review of sensitive outputs, periodic rotation or cross-training, a block-leave or cover period during which another person performs the duties, and enhanced transaction monitoring; measures are applied consistently, recorded, and reviewed annually for coverage and fairness.	COO / Chief People Officer / 90 days
18	Fraud Detection Capability	Close the material control weakness recorded for "Persisted control statement for D4-Qo2".	The monitoring owner generates a complete daily or weekly exception queue, assigns each alert to a trained reviewer, records investigation evidence and disposition, and escalates high-risk alerts immediately and all overdue alerts weekly; Risk performs a monthly closure-quality sample.	CFO / COO / 60 days
19	Fraud Detection Capability	Close the material control weakness recorded for "Persisted control statement for D4-Qo4".	The monitoring owner must reassess the detection set whenever a new fraud method is identified internally or externally, a material process or system changes, or a confirmed incident bypassed existing detection; each change is documented with rationale, tested against historical data before deployment, version-controlled, and reported with before-and-after coverage to the fraud forum.	CFO / COO / 90 days
20	Fraud Detection Capability	Close the material control weakness recorded for "Persisted control statement for D4-Qo5".	The monitoring owner must maintain a coverage matrix showing, for each material process, the indicators addressing internal misuse — override use, permission changes, adjustments by approvers, out-of-hours access — and those addressing external threats such as supplier impersonation, customer identity misuse and channel abuse; gaps in either column are logged with an owner, and coverage is reported to the fraud forum each cycle.	CFO / Chief Technology Officer / 90 days
21	Fraud Detection Capability	Close the material control weakness recorded for "Persisted control statement for D4-Qo6".	The Head of Risk must publish escalation criteria defining what must be escalated, to whom and within what time, grant monitoring staff explicit authority to escalate directly to the fraud-risk executive or audit-committee chair where a manager is implicated, protect escalators from retaliation, train the monitoring team annually, and review escalation timeliness against criteria each quarter.	Head of Risk / 30 days
22	Fraud Detection Capability	Close the material control weakness recorded for "Persisted control statement for D4-Qo7".	The audit committee must commission a periodic independent evaluation of detection effectiveness covering coverage against the process fraud maps, data completeness, sample retesting of closed alerts for closure quality, and detection of deliberately seeded test conditions where practical; findings are reported to governance with owners and due dates, and remediation is tracked to closure.	Audit Committee Chair / 90 days
23	Fraud Incident Response	Close the material control weakness recorded for "Persisted control statement for D5-Qo2".	The ethics owner must publish reporting routes in plain language across the channels the workforce actually uses — induction packs, payslip inserts, notice boards at depots and sites, intranet and supervisor briefings — covering line manager, confidential channel and conflict-free alternate route; awareness is tested periodically by short survey or spot check, and results below threshold trigger a targeted re-communication for the affected sites or teams.	Chief People Officer / COO / 30 days
24	Fraud Incident Response	Close the material control weakness recorded for "Persisted control statement for D5-Qo3".	The incident-response lead must publish a decision-rights matrix covering intake and severity classification, authorisation to investigate, appointment of the investigator, decisions on suspension, disciplinary referral, criminal or regulatory referral, recovery action and formal closure; each decision names a primary and deputy, states the conflict rule requiring recusal where the decision-maker is implicated or reports to someone implicated, and every decision is recorded in the case file with date and rationale.	COO / General Counsel / 30 days
25	Fraud Incident Response	Close the material control weakness recorded for "Persisted control statement for D5-Qo4".	The investigation lead must maintain written procedures covering need-to-know confidentiality and case access restriction, the subject's right to respond at the appropriate stage, interview conduct and record standards, contemporaneous documentation with dated file notes, retention and legal-privilege handling in consultation with Legal, and use of competent or accredited investigators; case files are quality-reviewed at closure against the procedure.	General Counsel / COO / 60 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
26	Fraud Incident Response	Close the material control weakness recorded for "Persisted control statement for D5-Qo6".	The incident-response lead must define engagement triggers such as suspected loss above a threshold, digital forensic imaging requirements, senior-management or governing-body involvement, cross-border elements or likely litigation; pre-qualify providers for forensic accounting, digital forensics and investigative legal support with confidentiality, privilege, data-protection and evidential-standard terms agreed in advance, and record the decision to engage or not engage in every qualifying case.	General Counsel / CFO / 60 days
27	Fraud Incident Response	Close the material control weakness recorded for "Persisted control statement for D5-Qo7".	The incident-response lead must run a documented post-incident review for every material case covering how the scheme operated, which controls failed or were absent, why detection was delayed, and what the loss and recovery were; each review produces control, process, training or monitoring actions with named owners and due dates, tracked in the remediation register, reported to the fraud forum, and verified after implementation to confirm the weakness is actually closed.	COO / 60 days
28	Whistleblowing and Reporting Culture	Close the material control weakness recorded for "Persisted control statement for D6-Qo3".	The ethics owner must apply documented routing rules at intake that identify implicated parties, exclude them and their direct reporting line from case access and decision-making, and route reports naming executives or the fraud-risk executive directly to the audit-committee chair; case-management access is role-restricted and logged, routing decisions are recorded per case, and conflicts discovered later trigger immediate reassignment.	Chair of Audit Committee / 60 days
29	Whistleblowing and Reporting Culture	Close the material control weakness recorded for "Persisted control statement for D6-Qo4".	The Chief People Officer must issue a written anti-retaliation commitment covering employees, contractors and, where relevant, suppliers; communicate it alongside every reporting-channel message; monitor employment outcomes for identified reporters for a defined period after a report including performance action, transfer, roster change and termination; provide a direct route to the audit-committee chair for retaliation concerns; and apply disciplinary consequences where retaliation is substantiated.	Chief People Officer / Chair of Audit Committee / 30 days
30	Whistleblowing and Reporting Culture	Close the material control weakness recorded for "Persisted control statement for D6-Qo5".	The ethics owner must make the reporting channel reachable externally through a public web route and published contact detail, reference it in supplier onboarding packs, contracts and purchase orders and in customer-facing material where relevant, accept anonymous external reports, and triage them under the same independence and conflict rules as internal reports with feedback provided where the reporter is contactable.	COO / Chief People Officer / 60 days
31	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Persisted control statement for D7-Qo2".	The procurement owner must require, above defined thresholds, that evaluation criteria and weightings are fixed and recorded before submissions are opened, submissions remain sealed until a scheduled opening witnessed by at least two people, evaluation is performed by a panel with signed conflict declarations, and single-source or emergency awards require documented justification and independent approval; a periodic analysis reviews award concentration, repeated near-identical pricing and rotating winners.	CFO / COO / 60 days
32	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Persisted control statement for D7-Qo3".	The compliance owner must require annual and on-change declarations from every employee able to influence supplier selection, contracting, receipting or payment, covering directorships, shareholdings, family relationships and outside interests; declarations are tested against the vendor master for matching surnames, addresses, contact details and bank accounts, and every declared or detected conflict receives a documented management action such as recusal, reassignment or enhanced review, recorded in a conflict register.	CFO / General Counsel / 60 days
33	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Persisted control statement for D7-Qo5".	The vendor-risk owner must define a risk-based monitoring cycle in which high-risk third parties are re-screened for ownership and sanctions change, reviewed for delivery and quality performance, tested for pricing drift against benchmark or contract, and analysed for spend concentration and unusual growth; findings requiring action are logged with owners, and failure to complete a cycle triggers escalation to the CFO.	CFO / COO / 90 days
34	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Persisted control statement for D7-Qo6".	The audit committee must commission periodic independent review of procurement and vendor management covering all vendor-master creations and amendments with approver identity, award patterns by buyer and supplier, spend outside approved contracts or thresholds, use of emergency and single-source routes, and policy exception volumes by individual; findings are reported to governance with owners and due dates and tracked to closure.	Audit Committee Chair / CFO / 90 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
35	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Persisted control statement for D7-Qo7".	The relationship owner must ensure every intermediary or outsourced arrangement defines in contract the fraud-control obligations, the limits of delegated authority, the right to audit and obtain records, incident-notification duties and consequences for breach; oversight includes reconciliation of transactions and collections handled on the organisation's behalf, periodic assurance over the provider's relevant controls, and review of any sub-contracting before it occurs.	COO / CFO / 90 days
36	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Persisted control statement for D8-Qo6".	The security operations owner must publish a clearly signposted route for staff and, where relevant, external users to report suspicious messages, unexpected account changes and suspected compromise, define monitored hours and target response times, connect reports directly into the alert triage and incident-response process, provide acknowledgement and outcome feedback, and track reporting volume and response time against target.	Chief Technology Officer / 60 days
37	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Persisted control statement for D8-Qo7".	The information security and digital owners must jointly run a periodic review of emerging digital fraud methods relevant to the organisation's channels, drawing on vendor and industry advisories, incident experience and peer reporting; each method is assessed against current preventive and detective controls, gaps become owned actions with due dates, and accepted risks are recorded with rationale and reported to the risk forum.	Chief Technology Officer / 90 days
38	Fraud Leadership and Governance	Close the material control weakness recorded for "Persisted control statement for D1-Qo2".	The Head of Risk must add fraud as a standing entry in the enterprise risk register with a named owner, documented inherent and residual ratings, explicit linkage to the fraud controls relied upon, an agreed risk-appetite statement and a scheduled reassessment date; any rating change requires written rationale retained with the register.	CEO / Managing Director / 30 days
39	Fraud Leadership and Governance	Close the material control weakness recorded for "Persisted control statement for D1-Qo3".	The fraud-risk executive must issue a standing report on a fixed cadence to a named forum using a stable template covering incidents opened and closed, gross and recovered loss, control failures identified, overdue remediation with ageing, and emerging-threat commentary; the forum minutes decisions and owners, and any missed reporting cycle escalates to the audit-committee chair.	CEO / Managing Director / 30 days
40	Fraud Leadership and Governance	Close the material control weakness recorded for "Persisted control statement for D1-Qo5".	The fraud-risk executive must maintain an approved fraud policy plus procedures covering prohibited conduct, prevention and detection duties by role, reporting routes, investigation and evidence handling, and disciplinary and recovery consequences; each document carries a version, approval date, owner and review date, is published where the whole workforce can reach it, and is reviewed at least every two years or after a material incident.	CEO / Managing Director / 60 days

E2. Definitions and score basis

Domain	Coverage	Reported Score
Fraud Leadership and Governance	100%	0/100
Fraud Risk Identification	100%	0/100
Operational Fraud Controls	100%	0/100
Fraud Detection Capability	100%	0/100
Fraud Incident Response	100%	0/100
Whistleblowing and Reporting Culture	100%	0/100
Third-Party and Supply Chain Fraud Risk	100%	0/100
Digital and Identity Fraud Risk	100%	0/100
Fraud Culture and Awareness	100%	0/100
Continuous Improvement and Fraud Risk Monitoring	100%	0/100

Priority (risk register) and materiality (findings) are derived from the assessment evidence and the deterministic methodology; neither is an independent risk assessment. Likelihood/impact ratings are qualitative, not statistical probabilities.